
Amazon CloudFront – Origin Access Control (OAC)

What is OAC?

Origin Access Control (OAC) is the **modern and recommended way** to securely connect your **Amazon CloudFront** distribution with your **Amazon S3** bucket or other origins. OAC replaces the older **Origin Access Identity (OAI)** mechanism.

It ensures that **only CloudFront** can access the origin, **preventing direct access** from the public internet.

OAI vs OAC

Feature	OAI (Origin Access Identity)	OAC (Origin Access Control)
Legacy	Older method	Recommended (new) method
IAM	S3 bucket policy references OAI	Uses signed requests and IAM service principal
Features	Basic S3 restrictions only	Supports advanced features like Lambda@Edge , S3 Object Ownership
Support	No support for SSE-KMS	Supports S3 Server-Side Encryption with KMS (SSE-KMS)

Why Use Origin Access Control (OAC)?

-  **Restrict direct access** to S3 buckets or custom origins
-  Ensure that only **CloudFront** can fetch content from your origin

-  Enforce IAM-based security controls (instead of public access)
 -  Replaces and improves on OAI with better compatibility and features
-

How OAC Works

1. You create an **Origin Access Control** in CloudFront.
 2. CloudFront **signs each request** it makes to your S3 origin using **SigV4 (AWS Signature Version 4)**.
 3. Your **S3 bucket policy** is configured to **allow access only to CloudFront** using OAC.
 4. Any request coming directly to the bucket (bypassing CloudFront) is denied.
-

OAC Components

- **OAC Configuration:**
 - Name
 - Signing behavior (Always or Never)
 - Signing protocol (SigV4)
 - IAM role (used internally by CloudFront)

- **S3 Bucket Policy:**
Allows access only to CloudFront service with specific OAC
-

How to Create & Use OAC (Step-by-Step)

Step 1: Create a CloudFront Distribution

- Origin: Amazon S3 (or other origin)
- Select **Origin Access** → Choose **Origin Access Control Settings**

Step 2: Create an OAC

- In CloudFront console → **Security** → **Origin Access Control**
- Click **Create Control**
- Choose:
 - **Signing Behavior:** Always
 - **Signing Protocol:** SigV4
 - **Origin Type:** S3

Step 3: Attach OAC to Origin

- In the CloudFront Distribution settings, select the created OAC for the origin.

Step 4: Modify the S3 Bucket Policy

Example policy:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowCloudFrontOAC",
      "Effect": "Allow",
      "Principal": {
        "Service": "cloudfront.amazonaws.com"
      },
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::your-bucket-name/*",
      "Condition": {
        "StringEquals": {
          "AWS:SourceArn":
            "arn:aws:cloudfront::123456789012:distribution/EXAMPLEDISTID"
        }
      }
    }
  ]
}
```

✅ Step 5: Test

- Try accessing the S3 URL directly → ❌ Denied
- Access via CloudFront → ✅ Allowed

🔄 Migration from OAI to OAC

If you're currently using OAI:

- Create a new **OAC**
 - Attach it to your distribution
 - Update S3 bucket policy
 - Remove the OAI reference
-

Hands-On Lab Idea

Lab: Secure S3 Access with CloudFront OAC

1. Create an S3 bucket with static content (disable public access).
 2. Create a CloudFront distribution with the S3 bucket as origin.
 3. Create and attach OAC.
 4. Update the S3 bucket policy.
 5. Access the content via CloudFront and confirm that direct S3 access is denied.
-